
Cuadernillo de Estudio — Clase 10

Del Hack al Negocio: Forense, Reporte Ejecutivo y Mesa de Crisis

Seguridad Aplicada a Sistemas de Información
Licenciatura en Sistemas de Información — Facultad de Informática y Diseño
Docente: Ing. Rodrigo Atilio Elgueta
Ciclo Académico Vigente

Índice

1. Objetivos de aprendizaje	2
2. La Mirada del Blue Team: Forense Post-Mortem	2
2.1. Las huellas que deja un Pentester	2
3. El Arte del Informe: Traduciendo el Caos	3
3.1. 1. El Resumen Ejecutivo (Para el CEO / Directorio)	3
3.2. 2. El Informe Técnico (Para el Gerente de IT / Sysadmins)	3
4. El Protocolo de Contingencia y la Mesa de Crisis	3
5. Ética de la Revelación (Disclosure)	4
6. Glosario de conceptos clave	4
7. Autoevaluación	4
8. Respuestas de la Autoevaluación	5
9. Recordatorio Final: Actividad A08	6
10. Fuentes y bibliografía	7

1. Objetivos de aprendizaje

En la Clase 9 y con la Guía de TryHackMe aprendiste a **pensar y actuar como un atacante (Red Team)**. El objetivo de esta Clase 10 es dar el giro profesional: aprender a **pensar como el defensor (Blue Team) y como el Directorio de la empresa**.

Al finalizar, serás capaz de:

- Analizar tu propio hack desde la perspectiva forense (¿qué rastro dejaste en los logs?).
- Traducir vulnerabilidades técnicas (CVEs) a **Riesgos de Negocio** (lucro cesante, multas legales).
- Estructurar un **Informe Ejecutivo** vs. un **Informe Técnico**.
- Diseñar un **Protocolo de Contingencia** y entender la dinámica de una **Mesa de Crisis (Tabletop)**.
- Cerrar la **Actividad A08** para INSECUR S.A. con un entregable de nivel corporativo.

El cambio de sombrero

Un *Script Kiddie* celebra cuando obtiene la flag de root. Un **Consultor de Ciberseguridad** celebra cuando logra que el Directorio apruebe el presupuesto para parchar la vulnerabilidad antes de que un atacante real la explote. Tu informe es tu verdadera herramienta de hacking.

2. La Mirada del Blue Team: Forense Post-Mortem

Cuando terminás tu pentesting en TryHackMe, la máquina queda comprometida. Pero, ¿cómo se dio cuenta (o no se dio cuenta) el administrador de sistemas de INSECUR S.A.?

Análisis Forense Digital (Post-Mortem)

Es la ciencia de preservar, identificar, extraer y documentar la evidencia informática. En un pentesting ético, debés documentar **qué huellas dejaste** para que el equipo defensor sepa qué buscar en sus sistemas de monitoreo (SIEM).

2.1. Las huellas que deja un Pentester

Al explotar una máquina, generarás ruido. Un buen informe le dice al cliente cómo detectar ese ruido:

- **Logs de Autenticación:** En Linux (`/var/log/auth.log`) o Windows (Event Viewer), quedarán registrados los cientos de intentos fallidos de tu ataque de fuerza bruta con Hydra, y el login exitoso posterior.
- **Logs de Servicios Web:** Si explotaste una Inyección SQL o subiste una Web Shell, el `access.log` de Apache/Nginx mostrará peticiones HTTP anómalas (códigos de estado 500, URLs con caracteres extraños como `UNION SELECT`).
- **Creación de Archivos:** Cuando subiste `linpeas.sh` o tu payload de Metasploit, el sistema de archivos registró la creación de esos archivos. Un antivirus o un sistema FIM (File Integrity Monitoring) debería haber alertado.

El valor agregado de tu informe

En tu informe para INSECUR S.A., no solo digas «Exploté el SSH». Agregá: «*El ataque generó 450 líneas de error en el auth.log en un lapso de 2 minutos. Recomendación: Configurar Fail2Ban para banear IPs tras 3 intentos fallidos y alertar al SOC*». Eso es pensar como Blue Team.

3. El Arte del Informe: Traduciendo el Caos

El Directorio de INSECUR S.A. no sabe qué es un *Buffer Overflow*, ni le importa tu script en Python. Ellos hablan el idioma del **Riesgo de Negocio**, el **Lucro Cesante** y la **Reputación**.

Tu entregable (A08) debe dividirse estrictamente en dos audiencias:

3.1. 1. El Resumen Ejecutivo (Para el CEO / Directorio)

- **Alcance y Metodología:** Qué se auditó y bajo qué reglas (ROE).
- **Hallazgos Críticos en lenguaje de negocios:** «*Se detectó que la base de datos de clientes está expuesta a internet sin contraseña. De ser explotada por un actor malicioso, INSECUR S.A. enfrenta multas millonarias por la Ley de Protección de Datos Personales (25.326), demandas colectivas y un daño reputacional que podría resultar en la pérdida del 20 % de la cartera de clientes*».
- **Nivel de Riesgo Global y Pedido de Inversión.**

3.2. 2. El Informe Técnico (Para el Gerente de IT / Sysadmins)

- **Fichas de Hallazgos:** CVE, CWE, CVSS, comandos utilizados y hashes de las flags como evidencia.
- **Remediación Técnica:** «*Actualizar Apache a la versión X.X.X*», «*Implementar la regla Y en el WAF*», «*Revocar el permiso SUID del binario /usr/bin/find*».

4. El Protocolo de Contingencia y la Mesa de Crisis

La consigna de A08 exige un **Protocolo de Actuación ante Fallas**. ¿Qué pasa si IT aplica tu recomendación de «actualizar el framework de la web» y, al hacerlo, la página de ventas de INSECUR S.A. deja de funcionar, deteniendo la facturación?

Mesa de Crisis (Tabletop Exercise)

Simulación teórica donde los roles clave de la empresa (CEO, Legal, IT, RRPP) se reúnen para ensayar su respuesta ante un incidente catastrófico (ej. Ransomware).

Un Protocolo de Contingencia profesional en tu informe debe dictar:

1. **Entorno de Homologación (Staging):** Prohibido aplicar parches de seguridad directo en Producción. Primero se prueban en un servidor espejo.
2. **Backups Previos (Snapshot):** Obligatorio tomar una instantánea del servidor antes de tocar configuraciones críticas.
3. **Ventana de Mantenimiento:** Aplicar cambios en horarios de menor tráfico.
4. **Plan de Rollback (RTO):** Si el parche rompe la aplicación, definir el procedimiento exacto para restaurar el backup en menos de *X* horas (**Recovery Time Objective**).

El puente hacia la Unidad VI

Si el parche falla y la empresa es atacada de verdad mientras está caída, se activa el **Plan de Continuidad de Negocio (BCP)**. Este concepto, que nace de tu informe de pentesting, es exactamente lo que evaluaremos en la Actividad A10 (Trabajo de Estrés por Roles ante un Ransomware).

5. Ética de la Revelación (Disclosure)

Al terminar el contrato, te encontrás con vulnerabilidades que no solo afectan a INSECUR S.A., sino a sus clientes o a software de terceros.

¿A quién le aviso?

- **Divulgación Responsable (Responsible Disclosure):** Reportar la falla en privado al vendor (ej. Microsoft, Apache) y darles un plazo (ej. 90 días) para lanzar un parche antes de hacer pública la vulnerabilidad.
- **Divulgación Completa (Full Disclosure):** Publicar el exploit y la vulnerabilidad de inmediato para forzar al vendor a actuar y advertir a la comunidad. (Altamente controversial y riesgoso legalmente).
- **Bug Bounty:** Reportar a través de plataformas oficiales (HackerOne, Bugcrowd) para obtener una recompensa económica y protección legal.

Como consultor de INSECUR S.A., tu contrato te obliga a la **confidencialidad absoluta**. No podés publicar los hallazgos en tu blog personal sin un acuerdo de divulgación (NDA) explícito.

6. Glosario de conceptos clave

Blue Team	Equipo defensivo encargado de monitorear, detectar y responder a incidentes.
Post-Mortem	Análisis forense realizado después de que un incidente o pentesting ha concluido.
SIEM	<i>Security Information and Event Management</i> . Software que centraliza y analiza logs.
Tabletop	Ejercicio de simulación de crisis en mesa, sin tocar sistemas reales.
RTO	<i>Recovery Time Objective</i> . Tiempo máximo aceptable que un sistema puede estar caído.
Rollback	Procedimiento de reversa para volver al estado anterior de un sistema tras una actualización fallida.
NDA	<i>Non-Disclosure Agreement</i> . Acuerdo de confidencialidad legal.

7. Autoevaluación

Respondé por escrito; luego verificá en la Sección 8.

1. Si durante tu pentesting en TryHackMe lanzaste un ataque de fuerza bruta con Hydra contra el puerto 22 (SSH), ¿en qué archivo de logs del servidor Linux debería el Blue Team ver tu rastro y qué herramienta administrativa sugerirías para mitigarlo?
2. En tu informe para INSECUR S.A., el Gerente de IT te dice: «*Tu recomendación de deshabilitar el protocolo SMBv1 es muy buena, pero si lo hacemos, las impresoras de red de la oficina dejarán de funcionar y el negocio se detiene.*» ¿Cómo resolvés este conflicto aplicando los conceptos de **Riesgo Residual** y **Contingencia**?
3. ¿Cuál es la diferencia fundamental entre el **Resumen Ejecutivo** y el **Informe Técnico** dentro de tu entregable para A08?
4. ¿Por qué un pentester ético está obligado por contrato a mantener la **confidencialidad** de los hallazgos y no puede publicarlos en redes sociales como un logro personal?

8. Respuestas de la Autoevaluación

Nota para el estudiante

Estas respuestas te servirán de guía para estructurar la sección de recomendaciones y contingencia de tu informe final.

Pregunta 1: Rastro Forense y Mitigación

Respuesta

El rastro de un ataque de fuerza bruta al SSH queda registrado en el archivo `/var/log/auth.log` (o `/var/log/secure` en distribuciones basadas en RedHat), mostrando cientos de intentos de autenticación fallidos (*Failed password for...*) desde la IP del atacante.

Mitigación sugerida: Implementar **Fail2Ban**, una herramienta que monitorea estos logs y actualiza las reglas del firewall (iptables) para banear automáticamente la IP del atacante tras un umbral de intentos fallidos. Además, sugerir deshabilitar el login por contraseña y forzar el uso de claves SSH asimétricas.

Pregunta 2: Conflicto IT vs Seguridad (Contingencia)

Respuesta

Este es un escenario clásico de **Riesgo Residual** y **Operatividad vs Seguridad**. No se puede forzar el parche si detiene el negocio. La solución profesional es:

1. **Mitigación compensatoria:** Si no se puede apagar SMBv1, se debe **segmentar la red** (VLANs) y bloquear SMBv1 en el firewall interno para que solo las IPs de las impresoras y sus servidores de impresión específicos puedan comunicarse por ese puerto, aislando el riesgo.
2. **Plan de migración (Contingencia):** Presupuestar el reemplazo de las impresoras legacy o la actualización de sus drivers a medio plazo.
3. **Aceptación de Riesgo:** La dirección de INSECUR S.A. debe firmar una «Aceptación de Riesgo» formal, asumiendo la responsabilidad de mantener una vulnerabilidad crítica activa por motivos operativos.

Pregunta 3: Resumen Ejecutivo vs Técnico**Respuesta**

- **Resumen Ejecutivo:** Redactado para la Alta Gerencia / Directorio. No contiene código ni comandos. Se enfoca en el **Impacto de Negocio** (pérdidas financieras, multas legales, daño a la marca), el nivel de riesgo global y las decisiones estratégicas que deben tomarse (ej. aprobar presupuesto para nuevos firewalls).
- **Informe Técnico:** Redactado para los Administradores de Sistemas y Desarrolladores. Contiene los CVEs, los payloads, las capturas de pantalla, las rutas de los archivos vulnerables y los pasos exactos (código, configuraciones) para **remediar** (parchar) cada vulnerabilidad.

Pregunta 4: Confidencialidad y Ética**Respuesta**

Un pentester ético firma un **NDA (Acuerdo de Confidencialidad)** y un contrato de servicios. Publicar las vulnerabilidades de un cliente sin autorización viola el contrato, expone a la empresa a ataques reales por parte de oportunistas que lean la publicación, y constituye un delito de violación de secretos y confidencialidad. El logro profesional se demuestra en la capacidad de remediar el problema en privado, no en la exposición pública de la debilidad del cliente.

9. Recordatorio Final: Actividad A08**Cierre de la Práctica de Vulnerabilidades y Exploit**

Cliente: INSECUR S.A.

Tareas: Completar Núcleo THM + Sala de Elección.

Entregable: Repositorio GitHub (legajo-XXXXX) con:

- Informe PDF (Resumen Ejecutivo + Fichas Técnicas + Protocolo de Contingencia).
- Carpeta de Evidencias (Capturas con username THM visible).
- Carpeta de Bitácoras (**history**).
- Hashes SHA-256 de las flags obtenidas.

Rúbrica de evaluación (A08):

Criterio	Peso	Foco de Evaluación
A. Recopilación	10 %	Fuentes, CVEs, documentación oficial.
B. Elaboración de documentos	25 %	Uso estricto de la Plantilla de Pentesting.
C. Presentaciones	10 %	Claridad del Resumen Ejecutivo.
D. Integración de Soluciones	25 %	Parches y Protocolo de Contingencia.
E. Selección de herramientas	20 %	Justificación de Nmap, Burp, Metasploit, etc.
F. Consciencia de buenas prácticas	10 %	Ética, ROE, Limpieza y Anonimización.

10. Fuentes y bibliografía

- TryHackMe. *Basic Pentesting & Pentesting Fundamentals*.
- NIST (2008). *Technical Guide to Information Security Testing and Assessment (SP 800-115)*.
- Chicano Tejada, E. (2023). *Auditoría de seguridad informática. IFCT0109* (2.^a ed.). IC Editorial — eLibro.
- Evans, L. (2019). *Ethical Hacking: The Ultimate Guide to Using Penetration Testing...*. Amazon Digital Services LLC — KDP.
- Weidman, G. (2014). *Penetration Testing: A Hands-On Introduction to Hacking*. No Starch Press.
- PTES (Penetration Testing Execution Standard): <http://www.pentest-standard.org/>